Sistemas de Informação Biomédicos

Tecnologias para SIBs: Segurança dos dados e Interoperabilidade

Sérgio Campos,
Alessandra Faria-Campos,
José Carlos Serufo Filho

O que é Segurança de dados (Informação) ?

Segurança da informação é um **conjunto de métodos** adotados estrategicamente para **gerenciar** e **prevenir** os riscos de roubo, perdas e danos dos dados, sistemas, redes, servidores e dispositivos.



A Importância da Segurança de dados (Informação)



Alinhamento com negócio

Segurança Cibernética

Governança de Dados

LGPD

Princípios para a Governança e Uso dos dados



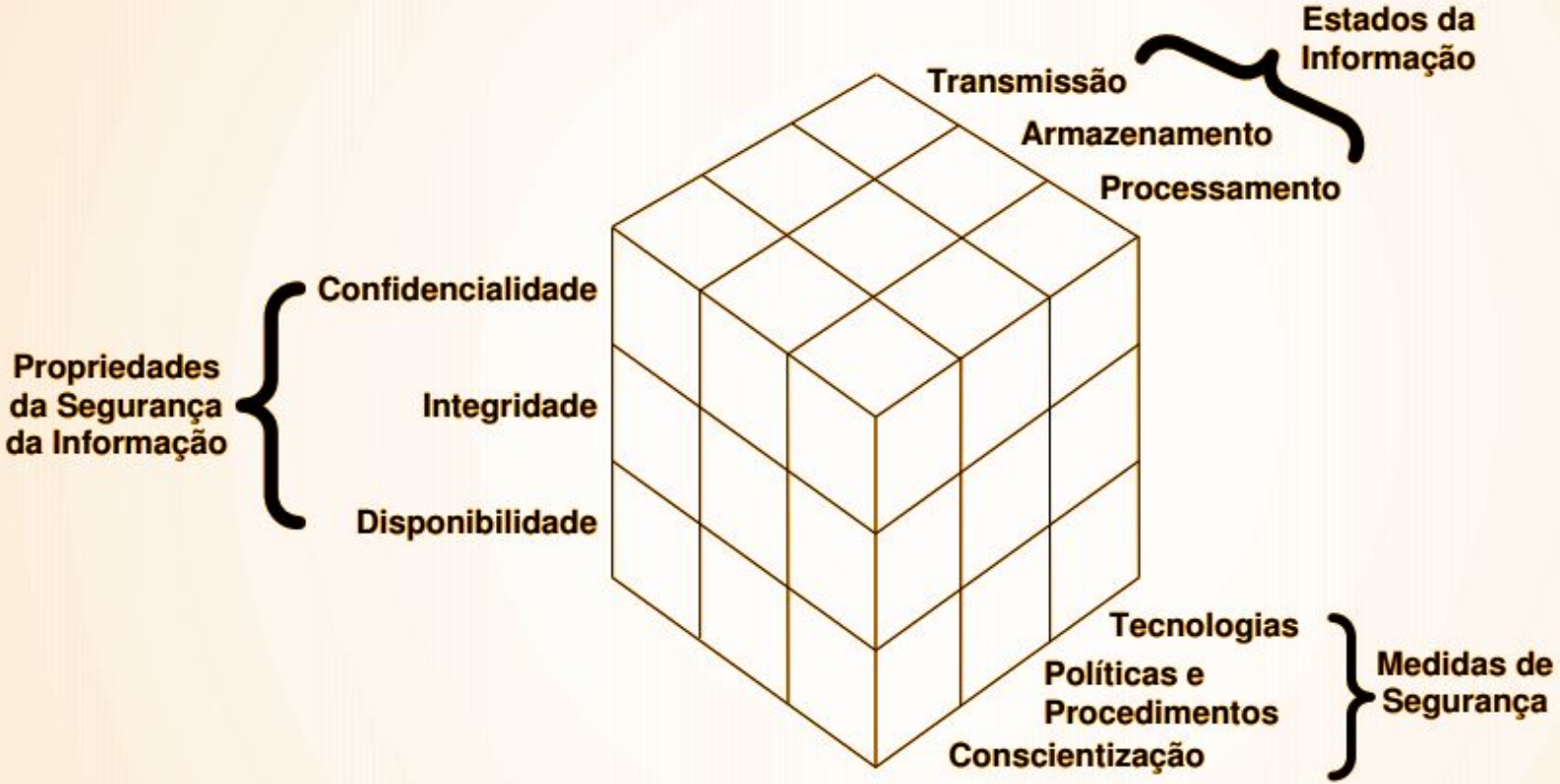
Funcionalidade, segurança e estabilidade

A estabilidade, a segurança e a funcionalidade globais das informações devem ser preservadas de forma ativa através de medidas técnicas compatíveis com os padrões internacionais e estímulo ao uso das boas práticas.

Propriedades da Segurança da Informação

- **Confidencialidade –** é a necessidade de garantir que as informações sejam divulgadas somente para aqueles que possuem autorização para vê-las.
- **Integridade –** é a necessidade de garantir que as informações não tenham sido alteradas acidentalmente ou deliberadamente, e que elas estejam corretas e completas.
- **Disponibilidade –** é a necessidade de garantir que os propósitos de um sistema possam ser atingidos e que ele esteja acessível àqueles que dele precisam.

As informações estão em diversos locais e a segurança depende de múltiplos fatores



Privacidade vs Confidencialidade

Privacidade – habilidade e/ou direito de proteger suas informações pessoais, estende-se à habilidade e/ou direito de prevenir invasões do seu espaço pessoal.

Confidencialidade – envolve a obrigação de proteger os segredos de outras pessoas ou organizações, se você souber deles.

Vulnerabilidade e Risco

Vulnerabilidade – Condição que, quando explorada por um atacante, pode resultar em uma violação de segurança.

Risco – é o potencial de que uma dada ameaça venha a explorar vulnerabilidades em um determinado ativo, de modo a comprometer a sua segurança.



Riscos em Sistemas Conectados à Internet

- indisponibilidade de serviços
- perda de privacidade
- furto de dados
- perdas financeiras
- danos à imagem
- **perda de confiança na tecnologia**

Sistemas na Internet



Riscos

Atacantes

- criminosos
- espionagem industrial
- governos
- vândalos



Vulnerabilidades

- defeitos de *software*
- falhas de configuração
- uso inadequado
- fraquezas advindas da complexidade dos sistemas

Acesso aos dados e sistemas

Controle de acesso – garantir que recursos só sejam concedidos àqueles usuários que possuem permissão.

- **Identificação** – permitir que uma entidade se identifique, ou seja, diga quem ela é.

Ex: conta de usuário, conta do banco, e-mail

- **Autenticação** – verificar se a entidade é realmente quem ela diz ser.

Ex.: senha, token, biometria



Como obter um sistema seguro?

Para conseguir uma segurança razoável tem-se tentado atingir os seguintes objetivos:

- Detectar comprometimentos o mais rápido possível
- Diminuir o impacto

Conter, mitigar e recuperar de ataques o mais rápido possível

Um sistema 100% seguro é muito difícil de atingir

Resiliência Operacional - Mudança de cultura

- Identificar o que é **crítico** e precisa ser mais protegido
- Definir **políticas** (de uso aceitável, acesso, segurança, etc)
- **Treinar** profissionais para implementar as estratégias e políticas de segurança
- Treinar e **conscientizar** os usuários sobre os riscos e medidas de segurança necessários

Continuar funcionando mesmo na presença de falhas ou ataques

Padrões de interoperabilidade

Permitem o **intercâmbio e representação** de informações clínicas, demográficas, administrativas, financeiras, operacionais, etc. entre sistemas heterogêneos;

- Podem ser de dois tipos: funcionais e semânticas;
- Podem ser nacionais e internacionais.

Principais padrões internacionais de interoperabilidade: **Health Level 7, IEEE, ASTM, openEHR, SNOMED CT**

IHE: Integrating the Healthcare Enterprise

Padrões de interoperabilidade

Permitem o **intercâmbio e representação** de informações clínicas, demográficas, administrativas, financeiras, operacionais, etc. entre sistemas heterogêneos;

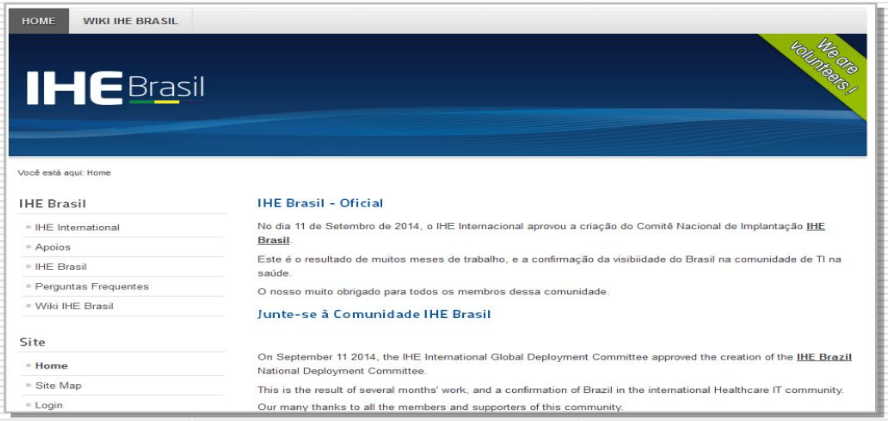
- Podem ser de dois tipos: funcionais e semânticas;
- Podem ser nacionais e internacionais.

Principais padrões internacionais de interoperabilidade: **Health Level 7, IEEE, ASTM, openEHR, SNOMED CT**

IHE: Integrating the Healthcare Enterprise

Organizações de padrões e certificação no Brasil









Portaria No. 2073/2012

Ministério da Saúde
Gabinete do Ministro

PORTARIA Nº 2.073, DE 31 DE AGOSTO DE 2011

Regulamenta o uso de padrões de interoperabilidade e informação em saúde para sistemas de informação em saúde no âmbito do Sistema Único de Saúde, nos níveis Municipal, Distrital, Estadual e Federal, e para os sistemas privados e do setor de saúde suplementar.

Adoção de padrões pelo Ministério da Saúde

- Registro Eletrônico em Saúde (RES): OpenEHR
- Interoperabilidade entre sistemas: HL7 - Health Level 7.
- Codificação de termos clínicos: SNOMED-CT
- Interoperabilidade com sistemas de saúde suplementar: TISS
- Arquitetura do documento clínico: HL7 CDA.
- Exames de imagem: DICOM.
- Codificação de exames laboratoriais: LOINC
- Modelos de conhecimento: ISO 13606-2.
- Identificadores de pacientes: IHE-PIX, CNS
- Classificações: CID-10, CIAP-2, TUSS e CBHPM

Referências: Fontes dos Conceitos Apresentados

Cartilha de Segurança para a Internet

http://cartilha.cert.br/

Security Engineering, 2nd Edition, 2008, Ross Anderson

http://www.cl.cam.ac.uk/~rja14/book.html

Glossary of Security Terms, SANS Institute

http://www.sans.org/security-resources/glossary-of-terms/

RFC 2196: Site Security Handbook

http://tools.ietf.org/html/rfc2196

Cyber Risk and Resilience Management, CERT/CC

http://www.cert.org/resilience/

serufo@ufmg.br